



GRC TOOLS EVALUATION

Selecting Governance, Risk & Compliance Software for ValNova Technologies

Prepared by Valentine John Ogoshi, GRC Manager	Company ValNova Technologies	Document Type GRC Tooling Evaluation	Date July 30, 2026
--	--	--	------------------------------

1. EXECUTIVE SUMMARY

ValNova Technologies is a scaling Nigerian fintech processing citizen, transaction, and cardholder data across payment, identity-verification, and government-facing platforms. This report evaluates five leading GRC/compliance platforms, Vanta, Drata, Sprinto, OneTrust, and Hyperproof, against ValNova's obligations under SOC 2, ISO 27001, PCI DSS, SOX ITGC, and NDPA/GDPR-style privacy regulation, using a weighted scoring model built around framework coverage, cost fit, automation, vendor-risk management, privacy depth, ease of implementation, customer support and onboarding, and auditor collaboration.

The recommendation is to deploy Sprinto as the primary, continuous compliance-automation platform and OneTrust as a complementary privacy and third-party risk platform. Sprinto scores highest overall on the weighted model on the strength of its cost fit and speed to certification. OneTrust is added despite a lower overall score because it uniquely covers privacy management and vendor risk, the two areas where ValNova carries the most regulatory exposure as a processor of citizen and cardholder data. The report also flags a material residual risk: both recommended platforms are foreign-hosted SaaS products, which raises NDPA cross-border data-transfer considerations that ValNova's legal function must actively manage. A five-phase, seven-month implementation roadmap, a RACI ownership model, and a KPI framework are included to move this recommendation from selection to operation.

2. COMPANY PROFILE

ValNova Technologies is a fictional Nigerian financial-technology (fintech) company that builds and maintains digital payment, identity verification, and government-facing service platforms. The company processes sensitive customer, transaction, and citizen data on a daily basis, handles cardholder data as part of its payment-processing services, and works closely with regulated partners in banking, capital markets, and public-sector institutions. As ValNova scales its client base across Nigeria and into other African markets, and as it begins supporting partners that are publicly listed or answerable to U.S. and international regulators, it must demonstrate strong data protection, information-security, and

financial-controls practices across the Nigeria Data Protection Act (NDPA) 2023, as implemented by the Nigeria Data Protection Commission's General Application and Implementation Directive (GAID) 2025, PCI DSS (for cardholder data), SOX internal controls over financial reporting (for listed partners and prospective public-company clients), and internationally recognised standards such as SOC 2 and ISO 27001.

As ValNova's full-time GRC Manager, I own the company's Governance, Risk, and Compliance function end-to-end, and evaluated five leading GRC/compliance software platforms against ValNova's daily operational needs: continuous control monitoring, evidence collection for audits, policy management, vendor/third-party risk oversight, and data-privacy compliance.

3. MISSION & VISION

Mission

To power secure, compliant, and inclusive digital financial and government services across Africa, giving banks, regulators, and citizens confidence in every transaction ValNova touches.

Vision

To be Africa's most trusted technology partner for financial and public-sector digital transformation, recognised globally for the strength of our governance, risk, and compliance practices.

4. EVALUATION CRITERIA

- Coverage of frameworks relevant to ValNova's operations, including SOC 2, ISO 27001, PCI DSS (cardholder data), SOX ITGC (internal controls for listed/regulated partners), and privacy regulations comparable to NDPA/GDPR.
- Automation of evidence collection and continuous control monitoring, to reduce the manual audit and evidence-gathering workload carried by the GRC function.
- Vendor and third-party risk management, given ValNova's reliance on banking, payment-processor, and government integration partners.
- Total cost of ownership and pricing transparency, appropriate for a scaling company rather than a large multinational enterprise.
- Ease of implementation and day-to-day usability for a lean, cross-functional compliance team led by a single GRC Manager.
- Customer support and onboarding quality, including the availability of a dedicated compliance or success contact, the support channels on offer (in-app chat, email, phone, and Slack), response coverage across our West Africa Time zone, and how much hands-on guidance the vendor provides through a first audit. For a lean GRC function pursuing its first certifications, the quality of vendor support is not a soft benefit; it directly determines how quickly ValNova reaches audit readiness and how much of the load falls on a single GRC Manager.

5. WHY THESE FIVE TOOLS WERE SHORTLISTED

Each of the five platforms below earned its place on the shortlist for a specific, defensible reason tied to ValNova's risk profile as a fintech handling cardholder data, citizen data, and relationships with regulated and publicly-listed partners.

Vanta: included because it is the market leader in framework breadth and integration depth (300+ integrations, 35+ frameworks including PCI DSS and SOX ITGC), and its Trust Center gives ValNova a fast, credible way to prove its security posture to banking and government partners during due diligence. This is a recurring requirement in fintech sales cycles. On support, Vanta offers in-product chat that escalates to a support specialist, alongside email, phone, a knowledge base, and a Slack-based practitioner community, though a dedicated account or success manager is tied to the higher plan tiers rather than provided by default.

Drata: included as the strongest technically-led alternative to Vanta, with class-leading multi-framework control mapping and a proven auditor-collaboration workflow. For a company like ValNova that will eventually run SOC 2, ISO 27001, PCI DSS, and SOX ITGC (available as a separate add-on) in parallel, Drata's crosswalk between frameworks reduces duplicate evidence work, which is a direct efficiency argument for a lean GRC team. Drata backs this with onboarding, in-product live chat to technical support and compliance advisors, and a customer success manager included in the contract, with structured implementation management available to some customers, though its core support coverage runs Monday to Friday rather than around the clock.

Sprinto: included because its unlimited-user, AI-driven model is priced and built for exactly ValNova's stage: a scaling company pursuing its first certifications rather than an enterprise with a large dedicated compliance department. Its documented ability to fast-track SOC 2 while simultaneously building PCI DSS readiness is directly relevant to ValNova's payment-processing obligations. Sprinto also stands out on support: it assigns a dedicated compliance expert to every customer, including on its lowest tier, and provides guidance over Slack, in-app chat, email, and calls scheduled around the customer's time zone, with 1:1 onboarding and audit advisory that suit exactly the kind of hands-on help a first-time compliance team at ValNova needs.

OneTrust: included because ValNova's core risk exposure is not only technical. It is data privacy and third-party risk. OneTrust is the only platform on this list built specifically for privacy regulation (NDPA/GDPR-style obligations) and for continuously monitoring the risk of the banks, processors, and government agencies ValNova integrates with, which the four compliance-automation-first tools address only partially. Its support, however, is structured in tiers: the included base tier runs on business hours only, while round-the-clock support, faster response targets, and a dedicated success manager sit behind premium packages, and independent reviews note that smaller accounts can feel deprioritised once the contract is signed. This is a factor ValNova must weigh at contracting rather than a reason to exclude the platform.

Hyperproof: included as the control case for ValNova's medium-term future. Once the company is running SOC 2, ISO 27001, PCI DSS, and SOX ITGC simultaneously across multiple business units, Hyperproof's 100+ framework library and dedicated audit-management workspace represent the natural next platform to evaluate, even though it is not the right fit for ValNova's current stage. Its support is a genuine strength, with live help by phone, email, and chat, a named success team spanning an implementation manager, customer success manager, and account manager, and a

private Slack channel on higher engagements, which reinforces why it remains the logical platform to revisit as ValNova matures.

6. COMPARATIVE OVERVIEW

The table below summarizes all five GRC/compliance platforms reviewed for ValNova Technologies, covering their category, core features, and indicative annual pricing.

Tool	Category	Key Features	Indicative Pricing (Annual)
Vanta	Compliance automation & trust management	Continuous control monitoring across 35+ frameworks, including SOC 2, ISO 27001, PCI DSS, SOX ITGC, NDPA-aligned GDPR, and HIPAA; 300+ native integrations (vendor marketing cites up to 400+); automated evidence collection; AI compliance agents; Trust Center for sharing security posture with clients and regulators. Support: In-app chat escalating to a specialist, plus email, phone, 24/7 live rep, knowledge base, and a Slack community; dedicated account/success manager on higher tiers.	From approximately \$10,000, scaling to \$80,000+ based on headcount and number of frameworks.
Drata	Compliance automation & continuous monitoring	Real-time control monitoring tied to live infrastructure; 20+ frameworks including SOC 2, ISO 27001, PCI DSS, and GDPR; SOX ITGC available as a separate paid add-on; 200+ integrations; policy centre; Trust Center; strong auditor collaboration workflow. Support: Onboarding, in-product live chat to technical support and compliance advisors, and a CSM included; implementation management for some customers; core coverage Monday to Friday.	From approximately \$7,500 (entry) to \$50,000+ for multi-framework, mid-sized deployments.
Sprinto	Autonomous compliance & risk automation	AI-driven continuous compliance across 20+ frameworks (SOC 2, ISO 27001, GDPR, HIPAA, PCI DSS); unlimited users at no extra cost; automated evidence mapping; risk register; entity/vendor risk management; fast implementation (weeks, not months). Support: Dedicated compliance expert on every plan including the lowest tier; Slack, in-app chat, email, and time-zone-aligned calls; 1:1 onboarding and audit advisory; 24/7 live rep.	Estimated at \$6,000 to \$30,000+ per year depending on frameworks and company size (Sprinto does not publish list pricing; figure is a third-party estimate).
OneTrust	Enterprise privacy, security & third-party risk GRC	Modular suite covering privacy management (GDPR, CCPA, NDPA-alignable), consent management, third-party/vendor risk exchange, AI	Third-party risk from approximately \$10,000; full GRC module from

Tool	Category	Key Features	Indicative Pricing (Annual)
		governance, and a dedicated Tech Risk & Compliance (GRC) module mapped to 50+ global frameworks, including PCI DSS and SOX ITGC. Support: Tiered support packages: base tier is business hours only; 24/7 coverage, faster response targets, and a dedicated CSM sit behind premium tiers; smaller accounts report weaker post-sale attention.	approximately \$50,000, scaling into six figures for enterprise deployments.
Hyperproof	Multi-framework compliance operations	Cross-framework control mapping and crosswalk; Hypersync automated evidence collection; audit management workspace; user access review automation; 100+ framework library including SOC 2, ISO 27001, GDPR, HIPAA, PCI DSS, SOX, NIST AI RMF, and ISO 42001. Support: Live phone, email, and chat with response times measured in minutes; named success team (implementation manager, CSM, account manager) and a private Slack channel on higher engagements.	From approximately \$12,000, with typical mid-market contracts averaging around \$40,000.

Note: Vendors listed above do not publish fixed public pricing; figures reflect ranges reported by third-party pricing analyses and vendor marketplaces as of 2026, and vary with company size, frameworks selected, and negotiated terms. Support details are drawn from each vendor's published support documentation and independent review platforms as of 2026, and specific support entitlements likewise vary by plan tier and contract.

7. WEIGHTED SCORING MATRIX

To move from narrative comparison to a defensible decision, each tool was scored 1 (poor fit) to 5 (excellent fit) against the evaluation criteria from Section 4, each criterion weighted by its importance to ValNova. The weighted total gives a quick ranking, but as the selection in Section 8 explains, the highest total score is not automatically the right choice when a lower-scoring tool closes a specific, high-severity risk gap.

Criterion	Weight	Vanta	Drata	Sprinto	OneTrust	Hyperproof
Framework Coverage (SOC 2, ISO 27001, PCI DSS, SOX, NDPA/GDPR)	20%	5	5	4	4	5
Cost Fit for ValNova's Current Stage	20%	2	2	5	2	3
Automation & Continuous Monitoring	15%	5	5	4	3	4
Third-Party / Vendor Risk	12%	3	3	3	5	3

Criterion	Weight	Vanta	Drata	Sprinto	OneTrust	Hyperproof
Management						
Privacy Management Depth	10%	3	3	3	5	3
Ease of Implementation	6%	3	3	5	2	3
Auditor Collaboration & Evidence Workflow	5%	5	5	3	3	4
Customer Support & Onboarding	12%	4	4	5	3	5
Weighted Total (out of 5.00)	100%	3.72	3.72	4.11	3.38	3.84

Sprinto returns the highest weighted total (4.11 / 5.00), driven by its strong cost fit, ease of implementation, and the dedicated compliance expert it provides on every plan, all of which matter for a company at ValNova's stage. Hyperproof follows at 3.84, lifted by its genuinely strong support model, with Vanta and Drata just behind at 3.72 each, held back mainly by cost. OneTrust scores lowest overall (3.38) on this weighted model, weighed down partly by a tiered support structure that offers smaller accounts less than the round-the-clock, dedicated attention its premium tiers carry. It is still selected as the second platform, precisely because it is the only tool that scores a 5 on both privacy management depth and third-party/vendor risk management, the two criteria most directly tied to ValNova's regulatory exposure as a processor of citizen and cardholder data. This is a deliberate example of judgment overriding a pure score. The model informs the decision; it does not make it.

8. FINAL SELECTION: SPRINTO & ONETRUST

Of the five platforms reviewed, Sprinto and OneTrust are the two selected for ValNova Technologies. The case for each, and for the pairing, is as follows.

8.1 Sprinto: Primary Compliance Automation Platform

Sprinto is the right foundation for ValNova's day-to-day compliance operations for four defensible reasons. First, cost discipline: its unlimited-user pricing (estimated at roughly \$6,000 to \$30,000 per year depending on frameworks and company size, based on third-party pricing analyses since Sprinto does not publish list pricing) lets every stakeholder across engineering, operations, and finance see control status without the per-seat costs that inflate Vanta and Drata contracts at ValNova's size. Second, speed to certification: Sprinto's documented track record of taking comparable companies from a standing start to SOC 2 readiness in weeks rather than months, while building PCI DSS readiness in parallel, matches ValNova's need to prove itself quickly to banking and payment partners. Third, direct relevance to ValNova's obligations: native support for SOC 2, ISO 27001, GDPR/NDPA-style privacy controls, and PCI DSS covers the majority of ValNova's near-term framework requirements in a single subscription. Fourth, hands-on

customer support: Sprinto assigns a dedicated compliance expert to every customer regardless of tier, and provides guidance over Slack, chat, and calls arranged around our time zone, which lightens the load on a single GRC Manager and shortens the path to a first certification, exactly the kind of support a lean team benefits from most.

8.2 OneTrust: Data Privacy & Third-Party Risk Management

OneTrust is selected as the second platform because ValNova's risk exposure extends beyond security-control automation into two areas none of the other shortlisted tools cover as deeply: data privacy and third-party risk. As a processor of citizen and cardholder data, ValNova must run data-protection impact assessments and manage consent in ways that map directly to the NDPA. OneTrust's Privacy Management module is built specifically for this. Equally, ValNova's business model depends on integrations with banks, payment processors, and government agencies; OneTrust's Third-Party Risk Exchange gives the GRC function a continuous, evidence-based view of those partners' security posture, rather than a one-time questionnaire. No compliance-automation-first tool in this review (Vanta, Drata, Sprinto, or Hyperproof) matches this depth of privacy and vendor-risk coverage.

8.3 Why Not the Other Three

- Vanta and Drata were not selected as primary tools because their pricing scales aggressively with headcount and framework count; at ValNova's current stage, that premium buys integration breadth the company does not yet need, when Sprinto already covers the same core frameworks at a fraction of the cost.
- Hyperproof was not selected now because its strength, managing many frameworks across multiple business units at enterprise scale, is a future-state need. Buying that capability today would mean paying for maturity ValNova has not yet reached; it remains the logical upgrade path once SOX ITGC and PCI DSS obligations expand beyond what Sprinto and OneTrust can efficiently cover.

Together, Sprinto and OneTrust give ValNova Technologies a lean but complete GRC stack: Sprinto handles continuous, day-to-day compliance automation and audit readiness for SOC 2, ISO 27001, and PCI DSS at a cost appropriate to a scaling company, while OneTrust covers the deeper privacy and third-party risk obligations, including groundwork relevant to SOX ITGC as ValNova's partners expand, that come from operating in the fintech and government-services space. This combination avoids the six-figure cost of a single enterprise suite while still closing ValNova's most business-critical risk gaps.

9. DATA RESIDENCY & CROSS-BORDER CONSIDERATIONS

One risk this selection does not eliminate, and should not obscure, is data residency. Both Sprinto and OneTrust are foreign-hosted SaaS platforms: Sprinto is US-headquartered and OneTrust processes data across its own global infrastructure. Nigeria's data protection regime (the Nigeria Data Protection Act, 2023, as implemented by the NDPC's General Application and Implementation Directive of 2025, which replaced the earlier NDPR in September 2025) restricts cross-border transfer of Nigerian personal data unless the receiving country has an NDPC adequacy decision, an approved transfer instrument such as standard contractual clauses is in place, or a narrow statutory exception applies. As of 2026, the United States has no NDPC adequacy decision, so ValNova cannot rely on adequacy alone for either vendor. Running ValNova's compliance evidence, citizen data references, and privacy assessments through platforms

hosted outside Nigeria is therefore not a neutral technical choice. It is itself a data-transfer event that the GRC function must govern.

Recommended mitigations: (1) execute NDPA-compliant data processing agreements with both vendors before go-live, including standard contractual clauses covering cross-border transfer; (2) confirm both vendors' data residency and sub-processor locations as part of vendor due diligence, and prefer regional hosting options where either platform offers them; (3) register ValNova as a data controller or processor with the Nigeria Data Protection Commission (NDPC) and document the cross-border transfer basis in its annual compliance audit return, as required under the NDPA; and (4) restrict what is uploaded into each platform, for example, referencing rather than storing raw citizen PII inside compliance evidence wherever possible. This consideration should be closed out during Phase 1 of the implementation roadmap below, before any live customer or citizen data flows into either platform.

10. IMPLEMENTATION ROADMAP

The rollout is sequenced so Sprinto delivers a fast, visible compliance win before OneTrust's deeper privacy and vendor-risk workstreams begin, and so data-residency safeguards are in place before any live data is processed.

Phase	Timeframe	Key Activities	Owner
Phase 1	Weeks 1–4	Discovery & scoping: confirm priority frameworks (SOC 2 and PCI DSS first; ISO 27001 and SOX ITGC on the roadmap), finalise Sprinto and OneTrust contracts, assign internal stakeholders.	GRC Manager, Exec Sponsor
Phase 2	Weeks 5–10	Sprinto deployment: connect infrastructure integrations, map controls to SOC 2 and PCI DSS, automate evidence collection, remediate initial control gaps.	GRC Manager, IT/Engineering
Phase 3	Weeks 11–16	OneTrust deployment: stand up the Privacy Management module, run baseline DPIAs, onboard critical vendors into the Third-Party Risk Exchange.	GRC Manager, Legal/DPO
Phase 4	Weeks 17–24	Deepen coverage: begin ISO 27001 control mapping, formalise SOX ITGC groundwork for listed partners, remediate outstanding findings.	GRC Manager, IT/Finance
Phase 5	Month 7+	Audit & continuous operations: engage an external auditor for SOC 2 Type I, transition to a continuous-monitoring cadence, report KPIs to the executive team quarterly.	GRC Manager, External Auditor

11. ROLES & RESPONSIBILITIES (RACI)

Tools do not run themselves. The table below assigns ownership across the core compliance activities ValNova will operate once Sprinto and OneTrust are live, using standard RACI notation: Responsible (does the work), Accountable (owns the outcome), Consulted (provides input), Informed (kept up to date).

Activity	GRC Manager	IT / Engineering	Legal / DPO	Exec Sponsor	External Auditor
Tool selection & contracting	R/A	C	C	A	I
Platform configuration & control mapping	A	R	I	I	I
Evidence collection & continuous monitoring	A	R	I	I	C
Vendor / third-party risk assessments	R/A	C	C	I	I
Privacy impact assessments (DPIAs)	A	C	R	I	I
Audit liaison & certification	R/A	C	C	I	R
Executive reporting on compliance posture	R	I	I	A	I

12. SUCCESS METRICS (KPIs)

The following metrics let ValNova's leadership judge, in concrete terms, whether the Sprinto/OneTrust investment is delivering the compliance outcomes this report promises.

Metric	Target	Measured Via
Time to SOC 2 Type I audit readiness	≤ 6 months from Sprinto go-live	Sprinto control-readiness dashboard
Share of controls continuously monitored/automated	≥ 85% within 90 days	Sprinto compliance score
Open audit findings per review cycle	Trending to zero; no repeat findings	Audit reports / Sprinto findings log
Critical vendors with completed risk assessments	100% annually	OneTrust Third-Party Risk Exchange
DPIAs completed before new data-processing activities launch	100%	OneTrust Privacy Management module
Mean time to remediate a failed control	< 14 days	Sprinto / OneTrust remediation tracker

13. RESIDUAL RISKS OF THIS APPROACH

- Vendor lock-in: migrating compliance history and evidence off Sprinto or OneTrust later would carry real switching cost, particularly once multiple audit cycles of evidence live inside each platform.
- Cross-border data transfer: as detailed in Section 9, both platforms are foreign-hosted, creating an NDPA compliance obligation that must be actively managed rather than assumed away.
- Dual-vendor dependency: ValNova's compliance posture now depends on the uptime, security, and business continuity of two external SaaS vendors rather than one; an outage or breach at either affects ValNova's own audit readiness.
- Integration overhead: Sprinto and OneTrust do not natively share data, so control evidence and vendor-risk findings will need a manual or lightly-scripted reconciliation process to keep both platforms consistent.
- Cost escalation: Sprinto's pricing scales with frameworks and OneTrust's with modules; as ValNova adds ISO 27001, SOX ITGC, and more third-party integrations, the combined contract cost should be expected to rise materially from the entry pricing quoted in Section 6.

14. CONCLUSION

Selecting the right GRC tools is foundational to delivering on ValNova Technologies' mission and vision. By pairing Sprinto's affordable, continuous compliance automation with OneTrust's specialised privacy and third-party risk capabilities, ValNova can pursue SOC 2, ISO 27001, and PCI DSS readiness, lay the groundwork for SOX ITGC as partner relationships grow, strengthen NDPA-aligned data protection practices, and build the trust required to retain and grow its banking and government client relationships, without over-investing in enterprise features the company does not yet need. The weighted scoring model, implementation roadmap, RACI ownership structure, and KPI framework in this report are intended to carry that decision through to an operating, measurable compliance programme rather than leaving it as a one-time procurement choice.